

Who Left the Door Open? Investigating the Causes of Exposed IoT Devices in an Academic Network

Takayuki Sasaki^{†§}, Takaya Noma^{†§}, Yudai Morii[†], Toshiya Shimura[†],
Michel van Eeten^{†‡}, Katsunari Yoshioka[†], Tsutomu Matsumoto[†]
[†] Yokohama National University, [‡] TU Delft

Abstract—Many studies have discovered internet-facing systems exposing services that are vulnerable to attack. These are often assumed to be misconfigured systems that are not meant to expose these services to the network, especially not in an enterprise network. In this study, we clarify the causes of the presence of IoT devices exposing Telnet and FTP in a university enterprise network. This also helps us to understand who is responsible. We scanned the network and found 185 IoT devices consisting of 30 device models exposing Telnet and 49 models exposing FTP. We sent out a security notification and a survey to device owners. The survey demonstrated that 2 out of 21 and 8 out of 41 owners intentionally enabled Telnet and FTP, respectively, on all their devices. After receiving the notification, 38 out of 47 owners said they were willing to take measures on at least one of their IoT devices. All except one of the devices of these willing owners were successfully remediated. When we investigated the manuals of the devices, we were able to confirm that there was no disclosure whatsoever of the exposed service in 15 out of 30 manuals for models with Telnet and 10 out of 49 manuals for models with FTP. We also confirmed, by combining a survey of the manufacturers with the device manuals, that 22 out of 30 and 29 out of 49 devices enabled Telnet and FTP by default, respectively. From the above results, we conclude that the presence of misconfigured devices was less driven by human errors of the owners and more by the choices of the manufacturers. The majority of owners were motivated to remediate the security risks once made aware of them.

Index Terms—IoT, security, surveys of owners and manufacturers, analysis of device manuals, notifications

1. Introduction

Researchers regularly discover network-facing devices that expose services that are actively being targeted by attackers. Think of connected devices running Telnet or industrial control system (ICS) protocols [1], [2], [3], [4]. This is typically seen as bad security practice, especially in enterprise environments. Hence, notifications are sent to try to warn the owners of the devices about the risks they are facing [5], [6].

The implicit assumption behind this work is that the mere presence of these devices constitutes a failure of the

owner to configure them correctly. There is some evidence that this assumption is correct for consumers, who generally lack the technical expertise to understand and configure services like Telnet [7], [8]. We know much less about enterprise environments, however, even though potential misconfigurations can be much more consequential there. Studies that conducted notifications for exposed enterprise devices, like ICS, did not directly engage the owners of the discovered devices to identify their knowledge and motivations. Enterprise owners, for example, might be aware of the risk, but they might have made a conscious risk trade-off to enable the service. If they are unaware of the risk, is this because of a lack of due diligence of the owner or because the manufacturer did not adequately disclose the presence of the risky service? Why would manufacturers include a service that is not disclosed to the owner? To phrase it more succinctly, we do not know the cause of why these devices exposing risky services are present in enterprise networks.

In this study, we aim to answer the question: what are the causes of the presence of devices exposing risky services in an academic enterprise network? We first discovered 185 IoT devices of 66 unique devices exposing Telnet and/or FTP in an academic enterprise network. We also discovered 32 non-IoT hosts, such as PCs and Linux servers running these services. We then combine five data collection methods to disentangle potential causes, focusing not only on the role of the owner, but also of the device manufacturer. We divide our investigation into five separate data collection efforts, each with its own sub-question.

SQ 1: Are enterprise device owners aware of their devices running risky services? We conducted a survey among owners of devices that were identified during device discovery and collected responses from 55 out of 57 owners. 21 out of 23 owners were unaware of at least one device exposing Telnet. For FTP, this was 33 out of 41. Only in a minority of cases did owners intend to use these services.

SQ 2: Are they willing to take mitigating measures? If they are not willing, why not? We asked device owners if they were willing to mitigate the risk presented by the exposed service. 38 out of 49 owners were willing to take measures on at least one IoT device. We then kept monitoring the network to see whether any measures were successfully implemented. Of the owners who said they were willing to take measures, over 85 out of 86 IoT devices running Telnet and FTP were remediated. Of the owners who indicated that they did not intend to remediate, the

§. Two authors contributed equally to this work.

majority answered that they could not take measures because the device specification did not allow disabling Telnet or FTP.

SQ 3: Do device manuals inform device owners about the presence of these risky services? We analyzed the manuals of the device models exposing risky services. In total, 15 out of 30 models with Telnet and 10 out of 49 models with FTP had no description whatsoever of the service in their manuals. Even if the manuals had descriptions of the services, manuals of only two models with Telnet and eight models with FTP included recommended security precautions for these services.

SQ 4: What are the manufacturer intentions for including insufficiently disclosed services? To answer the question, we sent a questionnaire to the 14 manufacturers of the devices with insufficient disclosure. We got responses from all of them (100%). By combining the manufacturers' responses with our analysis of device manuals, we confirmed that at least 22 out of 30 and 29 out of 49 device models enabled Telnet and FTP by default. All but one manufacturer indicated they were aware of Telnet and/or FTP running on their devices. Most claimed that Telnet's purpose was to manage the device, either by the owner or by the manufacturer. In both cases, it is hard to justify this not being fully disclosed to the owner.

SQ 5: What risks are posed to the devices running undisclosed risky services? We conducted penetration tests of the selected devices. Specifically, we tested seven device models and confirmed Telnet and/or FTP can be accessed using the same default password that was set for the WebUI. We also identified risks of configuration changes and malware infection.

The findings suggest that the cause for most exposed devices is the fact they are default-enabled and insufficiently disclosed in the manuals. These causes lie squarely in the domain of the manufacturers. Owners are mostly not aware of the risk exposure they incur. Once they are, they almost always take action. In sum, our main contributions are:

- We present the first cause investigation for exposed devices that combines a survey among device owners, network measurements, analysis of device manuals, a survey among manufacturers and penetration tests.
- Owners of exposed devices are mostly unaware of the presence of risky services. A minority of the owners intentionally enabled the services on all devices they own (2 out of 23 for Telnet and 8 out of 41 for FTP).
- Most owners (38 out of 47) were willing and able to take measures on at least one IoT device. Those who were not willing indicated that the device specifications did not allow them to turn off the services.
- Device manuals for 15 out of 30 devices with Telnet and 10 out of 49 devices with FTP did not disclose at all that the services are running. In addition, manuals for 28 out of 30 device models with Telnet and 41 out of 49 device models with FTP did not give security advice about the configuration of the risky services.
- We demonstrate that manufacturer choices drive the

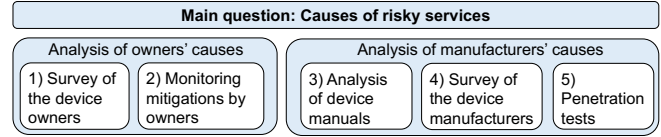


Figure 1. Overview of research steps

emergence of exposed devices. They often enabled the risky services by default (22 out of 30 for Telnet and 29 out of 49 for FTP) and yet do not properly disclose this to the owner. One manufacturer was not even aware that Telnet was running on its device. Another one told us that their device was never meant to be connected to the network, even though it was running Telnet by default. Penetration tests of the devices revealed that factory-default credentials can be used to cause configuration changes and malware infections using the exposed services.

By combining the five studies outlined above, we are able to shed light on the causes of the exposed devices found in the network. These studies highlight the responsibility of the manufacturers, rather than the owners.

2. Methodology

Figure 1 shows an overview of our investigation, consisting of five different data collection and analysis efforts. In this section, we outline each methodology.

2.1. Device discovery

We conduct our analysis in the enterprise network of an academic institution, in collaboration with the Chief Information Security Officer (CISO). The network is a Class B IPv4 network with 2^{16} IP addresses. A firewall is deployed between the network and the Internet. Inbound TCP sessions are rejected, except for traffic to specific IP addresses. Notwithstanding the presence of the firewall, the organization cannot solely rely on a perimeter defense. Devices in the network must themselves be secured because there is a possibility that a compromised system inside the network will provide a beach head for attackers.

From inside the campus network, we scanned the entire IPv4 space of the network to discover insecure devices. In this paper, we focus on Telnet and FTP because they are known attack vectors for the IoT and are used in many types of devices. They are also associated with the top 2 of the OWASP top 10 IoT security issues [9]. Some other high-risk protocols, such as SMB, are more specific to certain device types (e.g., printers), so we left them out of the scope of this study. We used a service named Karma [10] to identify hosts running Telnet (23/TCP) and/or FTP (21/TCP). In addition, we scanned HTTP services on the discovered hosts and retrieved the banner of the HTTP services and HTML to identify the device models.

We found 220 hosts in total. We identified 185 as IoT devices, 32 as non-IoT hosts, such as PCs and Linux servers,

and 3 hosts that we could not identify. As we discuss below, identification was primarily based on the survey among owners, supplemented with scanned banners (HTTP, Telnet, FTP, SSH) and the content of the WebUI.

Since the non-IoT hosts do not run Telnet and FTP by default, we assumed that these were consciously configured this way. We did notify their owners about the exposed service on their system, but did not include them in the rest of the investigation. The same holds for the three hosts that we could not identify.

Karma also identified IoT-specific security risks, such as whether the default ID and password were written in the manual, devices running outdated firmware, and end-of-life devices where the manufacturer's support has expired.

We repeated the scans in order to track whether owners deployed mitigations after we notified and surveyed them.

2.2. Notifications and surveys

The notifications and surveys were sent out to all device owners with IoT devices exposing Telnet and/or FTP. This happened in two phases, each with a specific questionnaire. We outline each phase below.

2.2.1. Notification timeline. Figure 2 shows the timeline of the scans and notifications to owners. We have conducted fifteen scans and two waves of notifications. To identify the targets of the first notification, we scanned twice: on July 21, 2021, and on September 16, 2021. We conducted the first notification over 19 days, from November 1, 2021 onwards. Then, we scanned once a week from November 10 to December 22, 2021, to measure the impact of the first notification.

After a short break, we conducted new scans from April 20–27, 2022. They were the basis for the second notification wave, which took place over nine days from June 1–9, 2022. To measure the impact of those notifications, we conducted further scans from June 29–August 3, 2022.

2.2.2. First notifications. We obtained the contact email addresses of the owners from the IT service center that manages all IP address assignments in the campus network. We then emailed the owners about the discovered devices, except for one owner who had passed away. Specifically, the notifications included a description of the IP address of the device, the security risks, and recommended mitigations. The notifications were sent by a staff member of the IT service center. In the notifications, we stated that the notification and questionnaire were part of a research project. The notifications were conducted in Japanese. A notification template translated into English can be found in the Appendix E.

As for the measures against the security risk, we recommended the following options:

- **Telnet and/or FTP service:** Stopping the Telnet/FTP service. If stopping the service is impossible due to the device specification, stopping usage of the device and/or replacement of the device were recommended.

- **Known default credential:** Changing the password (if the device still uses the default password).
- **Old firmware:** Firmware update.
- **End-of-life device:** Replacement of the device.

A staff member of the IT service center who sent the notifications emails to the owners, got contacted by some device owners who could not take measures by themselves due to a lack of IT knowledge. In three cases, we received requests for support from the owners. We made appointments and visited them for on-site support to solve the problems.

2.2.3. First survey. We attached a questionnaire to each email notification. Table 1 shows the questionnaire items and answer options (translated from Japanese). The questionnaire had response fields for multiple devices. To confirm the result of the device discovery, we asked whether the identified security risk was correct. In addition, we asked whether the owner was aware of the risk and, if the owner was conscious of it, for what reason they accepted the risk. We further asked whether they planned to take measures. If the owner indicated no intention to address it, we asked about the reason.

If the hosts with Telnet/FTP also had further security risks (known default credentials, outdated firmware, and end-of-life), we sent additional questions about those risks. The questionnaire template translated from Japanese is in Appendix H.

After we received the first questionnaire responses, we coded the open-ended responses, following the coding practices of earlier studies [11], [12], [13]. The coding was conducted by two researchers based on the following three steps:

Step 1: Generating labels: First, two researchers read through the responses to the question: “If you do not have plans to take measures, please let us know the reason.” They generated the following labels:

- **Insecure device specification:** The device could not disable Telnet/FTP by its specification.
- **Interfering with work:** The device was essential for research or work.
- **Password forgotten:** The device owner forgot the password.
- **Not knowing how:** The device owner does not know how to take measures.
- **Not knowing influence:** The device owner does not know the influence on their work if the device configuration would be changed.
- **Under consideration:** The device owner was considering potential measures and had not made a decision at the time of the questionnaire.
- **Already taken measures:** The device owner has already taken measures before the notification. This could be the case when the measures were taken between the scan and the notification. Another explanation is that the login function was disabled, but the port was still open and thus detected in our scans.

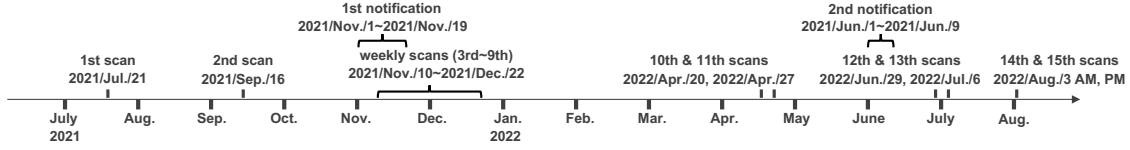


Figure 2. Timeline of device scans and notifications

TABLE 1. FIRST QUESTIONNAIRE ITEMS AND ANSWER CHOICES

Questions (for each device/IP address)	Answer choices
Q1. What type of device, manufacturer, and model number is using each IP address?	(Free form)
Q2. What is the usage (e.g., installation location) of the device?	(Free form)
Q3. Please select the status of TCP 23/21 port of the device.	Open / Closed / Unknown
Q4. Did you know that Telnet/FTP was running on the device?	Know / Didn't know
Q5. Please tell us why you are using the device in that configuration.	(Free form)
Q6. When was the last time you updated the firmware of your device?	(Free form)
Q7. Please tell us about the measures you intend to take.	Closing the port / Filtering the communications to the port / Replacement of the device / Stopping the usage of the device / No plans to take measures
Q8. If you selected "No plans to take measure" in Q7, please tell us why.	(Free form)

- **Already stopped using:** The device owner has already stopped using the device before the notification.
- **No answer:** The answer field is blank.

Step 2: Labeling: We manually checked whether each label matched each questionnaire answer and labeled the answer. **Step 3: Consistency check:** Once two researchers labeled the questionnaire answers, they resolved inconsistencies in label assignments by double-checking the answers and establishing consensus.

2.2.4. Second notifications. After the first notification, we conducted further scans. Some exposed devices were still found, even though the owners had indicated that they were willing to take measures. To notify them that the risks still remained, we conducted a second notification. We did not send out any second notification for the IoT-specific risks. All problems, except the default password issues, were confirmed to be fixed after the first notification. Ethical and legal reasons prevented us from independently confirming whether the known default password had been updated.

The second notifications were also conducted in Japanese, and a notification template translated into English is in Appendix F.

2.2.5. Second survey. The second notifications were accompanied by an additional survey meant to understand why the issue persisted. We asked the owners what measures they had actually taken, if any. The survey was sent out to a broader group than the notifications. We included all owners who had answered in the first survey that they were willing to address the risks. This includes owners who successfully remediated and those who did not. We did not send the survey to 13 owners who proactively contacted us after the

first notification. Three of them asked for help; the others sent us a report of the measures they took. In all these cases, we got the same information that the survey was meant to collect, so we could include their responses in the results.

Table 2 shows questions and answer choices. Similar to the first survey, the questionnaire had response fields for multiple devices. We categorized the owners into two groups: owners of not-remediated devices (Telnet and/or FTP were still running) and remediated devices. We asked all owners what actions they took after the first notification. Moreover, we asked whether the owner could lend the device(s) to us for assessing the security risks via penetration tests. If a device was not remediated and the owner indicated no measures had been taken, we asked for the reason. Additionally, we expressly asked if they would like on-site support. We received three support requests.

2.3. Analysis of device manuals

We obtained manuals from the manufacturer's product pages of the devices whose model numbers were identified. Then, we investigated the following items by examining the description of the manuals.

- Last update date of the manual
- A description of the Telnet/FTP service
- A description of a default credential for its management
- A recommendation for changing the default credential
- A recommendation for updating the firmware

If the manual has the description of Telnet/FTP, we investigated the following additional items.

- Whether Telnet/FTP service can be stopped or not.
- Whether the service runs by default.

TABLE 2. SECOND QUESTIONNAIRE ITEMS AND ANSWER CHOICES

Subject	Question	Answer choices
All owners	Q1. What measure did you take?	Closing the port / Filtering the communications to the port / Replacement of the device / Stopping the usage of the device / Asked on-site support / No measures taken / Other
	Q2. If the Q1 answer is "Other," please let me know the measure.	(Free form)
	Q3. Could you lend us the device?	Yes / No
Owners of not remediated devices	Q4. If "No measures taken", please let us know the reason.	(Free form)
	Q5. Would you like on-site support?	Yes / No

- Whether there is security advice about Telnet/FTP
- The stated purpose of Telnet/FTP service usage

For coding the manual contents, two researchers would independently code the content on the aspects mentioned above. They then checked the inconsistencies between them. If there were inconsistencies, the researchers discussed and resolved them.

Next, we examined whether each manufacturer has addressed the risky situation of the Telnet/FTP service by a firmware update. We obtained histories of firmware updates from the manufacturer's product pages and checked: (i) the last release date of the firmware and (ii) whether there was any mention of Telnet/FTP service in the firmware update histories.

2.4. Survey of device manufacturers

To understand the manufacturer intentions for including Telnet and/or FTP, we contacted their customer support. Since the university owns the devices, we could contact them as a customer. Specifically, we sent the questionnaires to customer support via contact forms on their Web sites or contact email addresses described on the Web sites. In the questionnaires, we asked the following questions.

- 1) What are these services used for? What operations are expected to be done using the services?
- 2) Do the services run by default without configuration by the owners?
- 3) What is the login credential for these services? (This question was included to check whether the credentials were meant to be used by the owner or by the manufacturer.)
- 4) Does the device have any security measures to mitigate the damage in case the device is compromised via the services? (e.g., restricting available commands or privileges)

If we had already found an answer to a question in a manual, we would omit the question from our survey in order to reduce the effort of customer support staff. The questionnaires were in Japanese. A translated questionnaire template is in Appendix G. Three researchers read through all responses and developed answer categories. These researchers then jointly coded all responses. Two researchers were bilingual, and they ensured the quality of the translation.

TABLE 3. THE NUMBER OF HOSTS AND IoT DEVICES

Owner Type	Hosts	Owners	IoT Devices	Owners
Researcher	68	41	43	34
Department staff	28	9	22	8
IT service center	77	1	76	1
Administration office	29	1	27	1
Attached school	18	5	17	5
Total	220	57	185	49

2.5. Penetration tests

For those devices where the manual did not have a description of Telnet and/or FTP running on the device, we evaluated the risks by purchasing and borrowing devices and conducting a penetration test via those two services. Specifically, against seven IoT devices, we manually investigated if attackers could gain access with default credentials and what a successful intrusion would allow them to do. Specifically, we tested which commands an attacker could issue via these services and which privileges are granted. As an additional test, we also examined vulnerabilities in the WebUIs that were also exposed to the network.

3. Device discovery

We scanned the campus network on July 16, 2021, and September 21, 2021, and identified 220 hosts with Telnet and/or FTP. This consists of 185 IoT devices and 32 non-IoT hosts. We could not determine if the remaining three were IoT or non-IoT. Within this set of 220, we also identified devices with certain IoT-specific risks: 5 devices with known default credentials, 3 devices running outdated firmware, and 3 end-of-life devices (Table 4).

We asked the IT service center about the registered owners for these 220 hosts: 68 hosts were managed by 41 researchers such as faculties, 28 hosts by 9 department staff, 77 hosts by the IT service center itself, 29 hosts by the administration office, and 18 hosts by five attached schools of the university (Table 3). About a quarter of the hosts were managed by the laboratories. The IT service center also had a large number of hosts, most of them being smart card readers.

Focusing on IoT devices, 185 (84%) out of 220 hosts were IoT devices and for 179 of them, model numbers were confirmed. Twenty-two device types of IoT devices running Telnet or FTP were found, such as multi-functional printers, electric current monitoring devices, display controllers, and Network Attached Storage (NAS). The device types are summarized in Table 15 in Appendix A.

In addition, we confirmed the release dates of the IoT devices, the latest firmware, and the manuals by exploring manufacturers' Web sites. The median year of device release was 2011, and the median year of the last firmware release date was 2019. The details are in Table 16 in Appendix B.

4. Survey of the device owners

We received responses from 55 out of 57 owners (of IoT and non-IoT devices). This nearly perfect response rate means we do not have to contend with bias caused by non-response, such as respondents having higher IT literacy or responsiveness to the security notification than non-respondents. The respondents are responsible for 181 out of the total of 185 IoT devices. Some owners manage a single device, and others manage several or even a large number of devices.

4.1. Telnet/FTP service

Did owners intentionally enable Telnet or FTP? Or were they unaware that devices were running these services by default? We investigated the awareness of owners and the default settings of the IoT devices. In Section 6 and 7, we discuss the default settings based on the descriptions in the manuals and the questionnaires to the manufacturers, but here we already include these results when discussing whether owners were aware.

Table 5 summarizes the results of the survey question in relation to the default settings. Of the 43 devices with Telnet enabled by default, only the owner of one device was aware of the service running. Similarly, of the 69 devices with default-enabled FTP, only owners of 8 devices were aware FTP was running. It suggests that most default-enabled services were running without the owners' awareness. Overall, most owners were unaware of services running: 21 out of 23 owners were unaware of at least one device exposing Telnet. For FTP, 33 out of 41 owners were not aware. Only in a minority of cases did owners intentionally run Telnet and/or FTP.

Remarkably, for devices that disabled by default Telnet or FTP, there were 2 cases for Telnet and 13 cases for FTP where the services were running, and yet the owners were not aware. It was unclear why the services were running. Owners might have delegated the administration of their devices to someone else and might not have been fully aware of their configurations.

Owners are responsible to update the firmware. In 147 cases (84%) out of 176 devices where the owners answered the question about the date of the last firmware update, the owners answered that they had not updated the firmware

or did not know whether they had updated the firmware. In other words, owners seemed to neglect to update the firmware. That being said, a firmware update would not have turned off the risky services by default, as our analysis of firmware update histories will show (Section 6.1).

4.2. Known default password

Five devices were identified by Karma as having known default credentials. The owners of four devices responded to the question about changing the password. The owners of three devices answered that the initial password had been changed already before they had received the notification. One owner answered that the password had been unchanged and was willing to address the issue.

Next, we examined the relationship between a recommendation for password change in the manual and whether owners changed their default passwords. For the four devices where we got questionnaire responses, the manuals of all devices recommended a password change. In three out of four devices, the passwords had indeed been changed before the notification. So, the manual does seem to influence the security behavior of the owner. It is not perfect, of course. For one out of the four devices, the owner responded that the password was unchanged, even though the device manual had the recommendation to change the password. This owner asked for on-site support, and we changed the password on his behalf.

5. Effectiveness of the notifications

Were owners willing and able to take mitigation measures after receiving our notification? Figure 3 shows a tree diagram where each box details the number of IoT devices exposing Telnet (left) and FTP (right). We track the status of these devices from whether they answered the survey, whether they indicated willingness to remediate (and if not, why not), how many devices remained exposed after the first notification and then after the second notification.

For IoT devices with Telnet, we found 119 IoT devices and received questionnaire answers from the owners of 118 IoT devices. Owners of 74 IoT devices said they were unwilling to take measures. The most common reason was that the owners could not turn off the services due to the device specification. Owners of 44 IoT devices said they intended to take measures. In the follow-up scans, we confirmed the successful remediation of 41 IoT devices.

Three devices with Telnet were not remediated after the first notification. Their owners were notified again, and two devices were subsequently remediated. The owner of the last remaining device said that he had already taken measures by disabling Telnet login. That still leaves the Telnet port open, which is why it still showed up in our scans. In a practical sense, though, this device is also no longer exposed.

As for IoT devices with FTP, we found 153 devices and received questionnaire answers from the owners of 150 devices. Owners of 79 devices answered they were unwilling to take measures, and the most common reason was, again,

TABLE 4. NUMBER OF DISCOVERED HOSTS AND SECURITY RISKS

	Total	Telnet	FTP	Known credentials	Outdated firmware	End of life
Discovered hosts	220	131	188	5	3	3
Owned by researcher	68	25	64	1	0	0
Owned by department staff	28	4	27	1	0	0
Owned by IT service center	77	74	66	0	0	0
Owned by administration office	29	15	24	2	2	2
Owned by attached school	18	13	7	1	1	1
Hosts with confirmed type (IoT + Non-IoT)	217	129	185	5	3	3
IoT devices	185	119	153	5	3	3
IoT devices with model number confirmed	179	116	150	5	3	3
Number of confirmed models of IoT devices	66	36	52			
Number of confirmed models of IoT devices with online manuals	60	30	49			

TABLE 5. DEFAULT TELNET/FTP SETTING OF IoT DEVICES AND OWNER'S AWARENESS OF THE TELNET/FTP STATUS

Default setting	Owner's awareness of each device			
	Telnet		FTP	
	Unaware	Aware	Unaware	Aware
Enabled by default	42	1	61	8
Disabled by default	2	1	13	3
Default unknown	15	57*	9	56*
Total devices	59	59	83	67

* Of these devices, 51 are smart card readers of the same model owned by IT service center.

device specifications that do not allow disabling the service – the same as for Telnet. For 71 devices, the owners did indicate the intention to take measures. From this set, 64 were remediated after the first notification, and all remaining seven devices were remediated after the second notification.

So, for all exposed devices, we find basically perfect remediation rates for owners who were willing to take action: 43 out of 44 for Telnet and all 71 devices for FTP, where the remaining one device was basically also remediated, according to the owner, but we could not independently verify this. A detailed breakdown of remediation rates after the two notifications is shown in Table 6. Overall, the results suggest that periodic scans and notifications are effective.

5.1. Mitigation actions by owners

Remarkably, the most common mitigation measure was simply stopping the use of the device (20 devices with Telnet and 20 with FTP). This raises questions for future research: Were these devices no longer really in use, and thus, could they be turned off without losing important functionality? Or did these owners give up functionality for the sake of security? Discarding devices as a security measure also raises sustainability concerns.

As for other measures taken by the owners, ten devices with Telnet and 27 devices with FTP (25 after the first notification and two after the second) closed the port of the

service. For 8 IoT devices with Telnet and 14 IoT devices with FTP, the owners filtered communications to the port of the service on IoT devices.

If we look at mitigation across all owners, including those who indicated they were not willing to take measures, we find that 53 (45%) out of 119 IoT devices running Telnet and 76 (50%) out of 153 IoT devices running FTP were remediated (Table 6). Interestingly enough, even some owners who said they were unwilling to take measures actually took action: 10 devices with Telnet and 5 with FTP were remediated. The reason why the overall remediation rate for Telnet was lower than FTP might be that many IoT devices running Telnet did not have descriptions of the Telnet service in their manuals. This would make it harder for the owner to take measures for Telnet than for FTP. We discuss this in Section 6.

As for the IoT devices with the old firmware and end-of-life devices, all devices have been remediated. As for the devices with known default credentials, one owner showed a willingness to change their passwords. However, the owner could not change the password by themselves, and we conducted on-site support to implement the change. One device was removed from the campus network by the owner. The owners of the remaining three devices claimed that they had changed the passwords, but we could not confirm this independently due to ethical considerations.

5.2. Comparison based on affiliation

The security awareness of device owners might differ according to their position in the organization. Therefore, we analyzed the differences in responses to notifications by dividing them into five categories based on affiliation. Table 7 shows the relationship between affiliation and the awareness of the Telnet/FTP services running on the IoT devices.

Researcher: Owners of 11 out of 14 (79%) IoT devices running Telnet and 27 out of 36 (75%) IoT devices running FTP were unaware of the services. The remediation rates were 11 out of 15 (73%) IoT devices for Telnet and 33 out of 39 (85%) IoT devices for FTP.

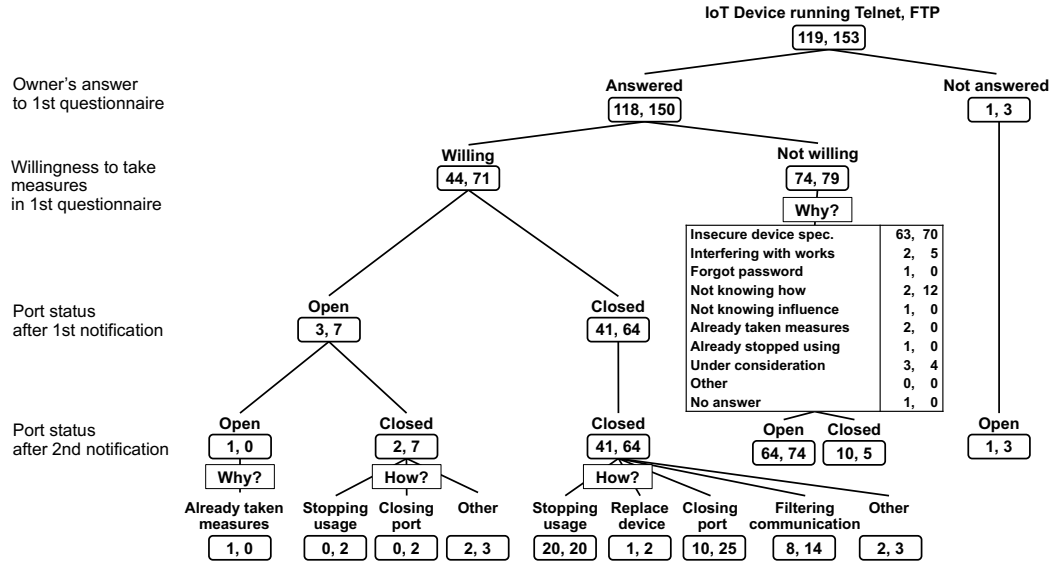


Figure 3. Number of IoT devices running Telnet and FTP

TABLE 6. NOTIFICATIONS AND REMEDIATED IoT DEVICES

Remediation rate (# Remediated IoT devices / # Risky IoT devices before the notification)						
Owner type	Telnet or FTP	Telnet	FTP	Known credentials	Outdated firmware	End of life
All owners	98/185 (53%)	53/119 (45%)	76/153 (50%)	2/5 (40%)	3/3 (100%)	3/3 (100%)
Researcher	35/ 43 (81%)	11/ 15 (73%)	33/ 39 (85%)	1/1 (100%)	0/0	0/0
Department staff	18/ 22 (82%)	4/ 4 (100%)	17/ 21 (81%)	0/1 (0%)	0/0	0/0
IT service center	21/ 76 (28%)	21/ 73 (29%)	10/ 65 (15%)	0/0	0/0	0/0
Administration office	12/ 27 (44%)	9/ 15 (60%)	11/ 22 (50%)	0/2 (0%)	2/2 (100%)	2/2 (100%)
Attached school	12/ 17 (71%)	8/ 12 (67%)	5/ 6 (83%)	1/1 (100%)	1/1 (100%)	1/1 (100%)
Willing to take measures	85/ 86 (99%)	43/ 44 (98%)	71/ 71 (100%)	1/1 (100%)	2/2 (100%)	2/2 (100%)
Researcher	30/ 31 (99%)	9/ 10 (90%)	29/ 29 (100%)	1/1 (100%)	0/0	0/0
Department staff	18/ 18 (100%)	4/ 4 (100%)	17/ 17 (100%)	0/0	0/0	0/0
IT service center	21/ 21 (100%)	21/ 21 (100%)	10/ 10 (100%)	0/0	0/0	0/0
Administration office	11/ 11 (100%)	8/ 8 (100%)	10/ 10 (100%)	0/0	2/2 (100%)	2/2 (100%)
Attached school	5/ 5 (100%)	1/ 1 (100%)	5/ 5 (100%)	0/0	0/0	0/0

Department staff: Owners of 4 out of 4 (100%) IoT devices running Telnet and 18 out of 21 (86%) IoT devices running FTP were unaware of the services. The remediation rates were 4 out of 4 (100%) IoT devices for Telnet and 17 out of 21 (81%) IoT devices for FTP.

IT service center: The IT service center was aware of the Telnet/FTP services, as one would hope from IT professionals. Out of the 76 IoT devices, 51 were the same model of smart card readers owned by the center. They were not remediated due to the fact that the device specification did not support this, and there was no alternative device to switch to.

Administration office: For most IoT devices, owners were unaware of the IoT devices running Telnet/FTP. The remediation rates were 9 out of 15 (60%) IoT devices for Telnet and 11 out of 22 (50%) IoT devices for FTP.

Attached school: There were no cases where these schools were aware of the Telnet, and for FTP, only one case where the owner was aware. They did not know the location of the device assigned to the IP address. Thus, a member of the IT service center visited the schools, investigated the details, and obtained the answers to the questionnaires. The remediation rates for Telnet and FTP were 8 out of 12 and 5 out of 6, respectively.

5.3. On-site support

We provided on-site support in five cases, at the request of device owners. All of these owners were researchers. Table 8 shows the date and time of the on-site support, risks, device type, and time used for the support. The same two persons provided all on-site support. All devices were

TABLE 7. OWNERS’ AWARENESS OF TELNET/FTP SERVICES RUNNING ON THE IoT DEVICES

	Telnet		FTP	
	Not aware.	Aware	Not aware.	Aware.
Devices with owner answers	118		150	
Researcher	11	3	27	9
Department staff	4	0	18	3
IT service center	17	56*	11	54*
Administration office	15	0	22	0
Attached school	12	0	5	1

* Of 56 and 54 IoT devices, 51 were IC card readers of the same model.

TABLE 8. ON-SITE SUPPORT

No.	Date	Risk	Device type	Time(min)
1	2021/Nov./13	FTP	Printer	30
2	2021/Nov./19	FTP	Multi-function printer	30
3	2021/Nov./26	Telnet, FTP, known credentials	Printer	20
4	2022/Jun./06	FTP	Printer	10
5	2022/Jun./14	FTP	Printer	5

located on the university campus, and travel time was not included in the time.

The average time required was 19 minutes, and the longest was 30 minutes. No. 1 to No. 3 were on-site support after the first notification, and No. 4 and No. 5 were after the second notification. The owner of No. 5 stated that he had intended to take measures after the first notification, but had forgotten to do so. Most of the device settings had not been changed from the default settings. Most owners were concerned that turning off Telnet and FTP functions would affect the use of their devices. We asked them how they used the IoT devices and confirmed that turning off Telnet/FTP did not affect their use of the device. So far, we have not received any reports of issues caused by disabling Telnet or FTP.

6. Analysis of device manuals

We collected and investigated device manuals in order to clarify whether device manuals informed device owners about the presence of these exposed services and their security risks. Specifically, we obtained manuals from the product websites of the manufacturer for the 179 devices where we had model numbers. These 179 devices consist of 66 unique models. We managed to find manuals for 60 of these device models (see bottom rows in Table 4).

6.1. Devices with Telnet/FTP

Table 10 summarizes the fraction of manuals that contain any security advice about Telnet and/or FTP, as well as whether the service is enabled or disabled by default. Stuningly, even for device models that enable the services by default, the majority do not include any security advice.

TABLE 9. DESCRIPTIONS OF THE PURPOSE OF TELNET/FTP IN IoT DEVICE MANUALS

Purpose of services	Telnet	FTP
Mentioned in manuals	10	36
Not mentioned in manuals	5	3
No description*	15	10
Total models	30	49

* No description of the service at all.

TABLE 10. DESCRIPTIONS OF SECURITY ADVICE ABOUT TELNET/FTP IN IoT DEVICE MANUALS

Default conf. in manual	Models with security advice on the secure usage in manuals			
	Telnet		FTP	
	No advice	Advice	No advice	Advice
Enabled	5 (17%)	1 (3%)	16 (33%)	1 (2%)
Disabled	3 (10%)	0 (0%)	9 (18%)	4 (8%)
Unknown	20 (67%)	1 (3%)	16 (33%)	3 (6%)
No disclosure ¹	15 (50%)		10 (20%)	
No default conf. ²	4 (13%)		6 (12%)	
Total models	28 (93%)	2 (7%)	41 (84%)	8 (16%)
	30 models		49 models	

¹ No description of the service at all.

² There was a description of the service but no mention of the default configuration.

Even worse, a large portion of the models do not even disclose at all in their manuals that these services are running: 15 out of 30 for Telnet and 20 out of 49 for FTP.

Even among the models with descriptions of the service in their manuals, of the 30 models running Telnet, five models did not mention the purpose of using Telnet (Table 9). In addition, only two models (7%) had descriptions of security advice, such as describing the risks of Telnet or advice on how to secure the device, such as disabling the service. Of the 49 models running FTP, 10 models (20%) had no description of the services, and three models had no description of the purpose of using FTP (Table 9). Only eight models (16%) had descriptions of security advice about FTP, such as changing the router configuration or disabling the service.

In other words, manufacturers often provided insufficient information or no information at all about the services, even when they were enabled by default. In such situations, it is difficult for owners to be aware of the security risks and take measures.

Do these findings reflect the security of an older generation of IoT devices, or is it a current problem? Appendix B shows that most devices were released from 2010 to 2018. Most firmware was released in 2019 or later, so it is quite recent. To test newer devices, we purchased eight successor models (Appendix C). We identified that one device enabled Telnet, and two devices enabled FTP by default. We cannot generalize from such a small sample, but this result suggests that manufacturers still put such risky devices into the market.

6.2. Devices with known default credentials

We investigated whether the manuals disclosed the default passwords used to manage devices. For 56 models, the manuals contained information on the default password. Of these, 51 devices had the same default password for all devices of that model. Of these 51 models, the manuals for 32 models did not include the recommendation to change the default password. These manuals' security advice to owners was wholly inadequate. The five remaining models had passwords based on the MAC address or serial number. In one model, an inquiry to the manufacturer to confirm the password was required.

7. Survey of manufacturers

In order to send a questionnaire to the manufacturers, a representative of the CISO of the university contacted the manufacturers' customer support channel since the university owned the devices and is thus a customer. We sent questionnaires to 14 manufacturers of 27 device models whose manuals (i) had no description at all of the Telnet/FTP service (18 models); (ii) had no description of the purpose of usage of the service (6 models); or (iii) where the manuals could not be obtained from the manufacturer's website (3 models). All manufacturers were Japanese companies, and the questionnaires were conducted in Japanese. We received answers from all manufacturers, so we obtained a 100% response rate.

Table 11 shows the summary of the answers about Telnet and FTP, respectively. Note that the numbers of subject manufacturers were different for each question item because we omitted a question if we had been able to find the answers in the manuals, in order to reduce the effort of customer support. The numbers in the right-most column combine the results from the survey plus our own analysis of the manuals.

What are these services used for? For 16 out of 22 device models, the manufacturer indicated that Telnet was used for management. In many cases, the answer was not clear as to whether the management function is for owners or manufacturers. If it is meant for owners, this is strange since there was no description in the manual. If it is meant for manufacturers, it is also strange because the manufacturer did not disclose to the owner that they have access to the device. For 6 out of 22 device models, the purpose of usage was unknown even to the manufacturer (or at least to the extent that customer support was able to find out). Surprisingly, one manufacturer was unaware of Telnet running on the device. We will confirm the severity of the issue and then responsibly disclose the vulnerability to the manufacturer and the National CERT, if necessary. Also remarkable: one manufacturer answered that the device was not supported to be connected to the network. If this is the case, then why does the model have a network function, and is it running Telnet?

As for FTP, some printers have a function that prints files uploaded by FTP. In 7 out of 12 devices, FTP was

used for this function. In 3 out of 12 devices, FTP was used for the transfer of collected data, such as the temperature data of the thermometer.

Do the services run by default without configuration by the users? According to the manufacturers' answers, 21 out of 22 models running Telnet and 10 out of 12 models running FTP enabled these services by default. Table 12 shows the combined analysis of the survey and the descriptions of the services in the manuals. We confirmed that at least 22 out of 30 and 29 out of 49 devices enabled Telnet and FTP by default, respectively.

What are the login credentials for these services? Manufacturers of 16 out of 22 and 10 out of 12 devices running Telnet and FTP answered our question to send us the login credentials. Among those answers, manufacturers of 6 models stated that the devices have no password for FTP. Manufacturers of 10 device models with Telnet and 5 models with FTP disclosed the credentials without identifying the device instance, which implies that they use common credentials for the same models. This increases the severity of the issues as the adversary could target any instances of the products once the common credentials are obtained.

Manufacturers of 6 out of 22 (Telnet) and 2 out of 12 (FTP) models answered that they did not disclose the passwords to the owners. In these cases, we assume that Telnet and FTP would be used by the manufacturers for management. As we discussed above, in many cases, this is not disclosed to the owner – a glaring omission.

Does the device have any mitigating security measures in place? The manufacturers answered that 21 out of 22 models running Telnet and 9 out of 12 models running FTP did not have security measures when the devices were compromised via those services.

Interestingly, while there was no security advice in the device manuals, in the survey responses, manufacturers of 6 out of 27 devices said that the owner was supposed to implement security measures. For example, using complex passwords, IP filtering, and using a VPN. These recommendations should be written in the manuals, not answered in response to a query exposed services that are often not even disclosed in the manual. In addition, one manufacturer offered to turn off Telnet using a management function for the manufacturer. The manufacturer should allow the owners to change configurations of risky services by themselves, not based on a request to the manufacturer.

From these results, we conclude that the manufacturers were aware of Telnet/FTP services but failed to provide security information about the services or even any information at all. In addition, manufacturers provide devices with default-enabled risky services, with a known default password, and without additional security measures when the devices are compromised through this vector.

8. Penetration tests of devices

In addition to the analysis based on manuals and questionnaires described above, we evaluated the risks of Telnet and FTP services by purchasing two devices and borrowing

TABLE 11. RESULTS OF QUESTIONNAIRES TO DEVICE MANUFACTURERS

Telnet: #Total device models = 22 , #Manufacturers = 10			FTP: #Total device models = 12, #Manufacturers = 9		
Question #Subject models(Manuf.)*	Manufacturers' answers	#Models (#Manuf.)	Question #Subject models(Manuf.)*	Manufacturers' answers	#Models (#Manuf.)
Q1. Usage of Telnet 22 (10)	For management	16 (8)	Q1. Usage of FTP 12 (9)	For remote printing	7 (4)
	Don't know the purpose of Telnet	5 (1)		For data transfer	3 (3)
	Don't know Telnet service itself	1 (1)		For management	1 (1)
				Not disclosed to owners	1 (1)
Q2. Default enabled 20 (10)	Enabled by default	21 (9)	Q2. Default enabled 11 (9)	Enabled by default	10 (7)
	Don't know	1 (1)		Disabled by default	1 (1)
Q3. Login credentials 22 (10)				Not disclosed to owners	1 (1)
	Disclosed in answer	16 (6)	Q3. Login credentials 12 (9)	Disclosed in answer	10 (7)
	Don't know	1 (1)		Not disclosed to owners	2 (2)
Q4. Security measures 22 (10)	Not disclosed to owners	5 (3)	Q4. Security measures 12 (9)	Not deployed	9 (6)
				Deployed	2 (2)
	Don't know	1 (1)		Not disclosed to owners	1 (1)

*The numbers of subject manufacturers were different for each question item because we omitted the question items if we could find the answers in the manuals to reduce the effort of customer support. The right column shows the compensated results by analysis of manual descriptions.

TABLE 12. COMBINED ANALYSIS OF DEVICE MANUALS AND QUESTIONNAIRES TO MANUFACTURERS ABOUT THE DEFAULT CONFIGURATION

Default configuration	Telnet	FTP
Default enabled	22	29
Default disabled	3	13
Default unknown	5	7

five devices that did not have a description of Telnet or FTP in the manual at all (Table 13)¹. Note that one limitation is that the purchased devices might not run the exact same firmware version of the devices in our campus network.

As for the risks of Telnet, four out of the six devices with Telnet used the same default ID/password of the WebUI also for Telnet authentication. As a severe risk (Device 5 in Table 13), we confirmed that a web camera allowed Telnet users to read/write any files with root privileges using the default password. Thus, the attacker could perform any attack, e.g., malware installation.

In our survey (Section 7), most of the manufacturers answered that the devices did not have specific security measures in place for when the devices would be compromised via the service. However, we identified that some generic measures were deployed. As for the capability of Telnet accesses, three of these devices (Devices 1, 2, and 3 in Table 13) allowed Telnet users to change device configuration using dedicated Telnet applications and did not allow the use of an interactive shell such *sh* and *bash*. In these IoT devices, the risk of malware infection was mitigated, but the attacker could still change the configurations.

As for risks of FTP, five devices used the same default ID/password of the WebUI for FTP authentication. Device

5 in Table 13 allowed FTP users to access system folders without restrictions on FTP commands. Device 7 allowed executing *ls* for system folders but could not write the files due to permission restrictions. Devices 1, 3, and 4 did not allow FTP users to access system folders.

In addition to the above risk evaluation, we conducted penetration tests on the WebUIs and discovered vulnerabilities such as Cross-Site Scripting (XSS) and Cross-Site Request Forgery (CSRF). A possible zero-day is currently under inquiry by manufacturers via the national CERT. In a severe case, an attacker can access the WebUI using a fake session Cookie without the admin password. We reported the vulnerabilities to a national CERT. At this moment, a vulnerability has been fixed, and a CVE number has been issued. The details of penetration test results are shown in Table 18 in Appendix D.

We also examined the firmware update histories in order to investigate whether manufacturers had taken measures against the exposed Telnet/FTP services in the latest firmware (Table 14). There was no information about Telnet or FTP services in the update history of any of the devices. Therefore, it seems unlikely that the manufacturers had addressed the running Telnet and FTP services by updating the firmware. In addition, 20 of the 37 firmware updates were made in 2019 or later, and the Telnet and FTP services were working even on relatively new devices (Details are in Table 16 in Appendix B).

9. Discussion: Analysis of causes

The picture that emerges from our investigation, across the five different studies, is that the presence of these exposed devices on the network is less reflecting the negligence or incompetence of owners than the choices of the manufacturers, most notably: running these services by default and either not disclosing them at all to the owners or not providing adequate security advice. To recap, the

1. We anonymize manufacturer names and device models to avoid the results being used for attacks. We will provide the non-anonymized data for researchers on a request basis.

TABLE 13. SECURITY RISK EVALUATION OF TELNET AND FTP

The date column summarizes the dates of device release and the latest version of the firmware. In Telnet/FTP column, "In Manual?" means whether the manual had a description of Telnet/FTP. "Def. PW?" means whether authentication succeeded with the same default ID/password of WebUI. "Restricted?" means whether available commands or accessible directories were restricted.

#	MF.	Device type	Release Date (Year/Month)		Telnet			FTP		
			Device	Latest FW	In Manual?	Def. PW?	Restricted?	In Manual?	Def. PW?	Restricted?
1	A	Printer	2010/May	2018/May	No	Yes	Yes	Yes	Yes	Yes
2	A	Network adapter for printer	2005/Dec.	unclear	No	Yes	Yes	-	-	-
3	B	Printer	2009/Jan.	unclear	No	Yes	Yes	No	Yes	Yes
4	C	Multi-function printer	2015/June	2020/Mar.	No	No	-	Yes	Yes	Yes
5	D	Web camera	2006/Apr.	2007/Mar.	No	Yes	No	Yes	Yes	No
6	E	Router	2011/Oct.	2017/Nov.	No	No	-	-	-	-
7	F	Data logger	unclear	unclear	-	-	-	No	Yes	Yes

TABLE 14. FIRMWARE UPDATE HISTORY

	Telnet	FTP
No information on updates	1 (5%)	3 (9%)
No details on updates	17 (85%)	23 (72%)
Security updates but not for Telnet/FTP	2 (10%)	6 (19%)
Explicit descriptions on Telnet/FTP	0 (0%)	0 (0%)
Total (IoT models with FW update histories)	20	32

manufacturer enabled the exposed services by default for a majority of devices. For a large portion of these devices, they did not disclose in the manual that these services were running. Only a small fraction of manuals provide security advice for FTP or Telnet.

Of course, one could argue that owners can also scan their own devices and discover these services, just like we have done. However, that would be making the owners responsible for tasks that are clearly on the side of the manufacturers: disclosing the presence of services to the owner, disabling the services by default where possible, and providing adequate security advice on their usage. If manufacturers do none of these things, then exposed devices will show up on the network.

An important model in safety science is James T. Reason's so-called Swiss Cheese model [14]. The key point of the model is that an incident cannot be traced back to a single cause; accidents are often the result of a combination of factors. Here, the manufacturers are stacking up the factors against the owners. The inevitable result is that devices are exposed and, at some point, compromised. The "human error" on the side of the owner is just the last step in a chain of security flaws, not the root cause.

To characterize these problems as "misconfigurations" by owners, as many studies implicitly do, is basically a form of victim blaming. As our survey showed, 21 out of 23 of the owners were unaware of at least one device exposing Telnet. For FTP, 33 out of 41. Once owners were made aware by us, they all remediated the situation perfectly, unless the device specifications did not allow them to do so. The latter points, again, to the manufacturers. We are not absolving owners of all responsibility, but they should also be able to rely on responsible behavior from the manufacturers.

10. Limitations

Our investigation combines a series of data collection and analysis efforts, looking at a broader set of factors than has been done in prior work. That said, this approach is only feasible if one focuses on a specific case, in our case: the university enterprise network. The limitations that this implies have to do with generalizability. First, how representative is a university enterprise network for other enterprise networks? The latter category comprises an enormous variety, so no single network could ever claim to represent that whole class.

University networks are perhaps less centrally managed than many enterprise networks – though we know of no research on the population of enterprise networks that allows us to evaluate to what extent this is true. Each laboratory manages some of its own devices. We believe that an enterprise network of a company often shows similar characteristics, with different departments and divisions often also managing some of their own devices. If this were not true, the problem of "shadow IT" would be non-existent in enterprise networks.

That said, there are characteristics that reflect the academic nature of the network. It contains devices that will reflect some of its academic activities. Finally, the network is located in Japan, which is also reflected in the set of manufacturers associated with the discovered devices. Are the security practices of Japanese manufacturers on average worse, better or the same as those in other countries? We do not know.

The response rates to our surveys have been stellar and basically 100% for both owners and manufacturers. Therefore, the usual reflection on selection bias introduced by non-responses can be omitted from this discussion. That being said, we send out the questionnaires only to manufacturers that provided insufficient information in the manuals and to manufacturers that did not provide the manuals on their websites. Thus, the questionnaire results might be biased towards manufacturers with lower security awareness. Additionally, as mentioned above, all manufacturers are Japanese companies, and that might introduce bias.

11. Ethical considerations

We obtained institutional review board (IRB) approval from the institution of the main authors where the study was conducted. We received approval for the network scan and for sending the notifications and surveys to the device owners from the Chief Information Officer (CIO) and Chief Information Security Officer (CISO). We inferred the presence of default passwords from the device model information, not by actually trying to log in to the devices.

The questionnaire invitation clearly states that it is part of a research study and cooperation is voluntary. We only disclose statistical data and no personal information is included in this paper. As for the survey of the manufacturers, answers were also statistically processed, and the manufacturer names and device model names were anonymized. We will contact industry associations to report the lack of proper disclosure by manufacturers as a consumer protection issue.

Regarding responsible disclosure of the vulnerability discovered by our penetration tests, we notified the vulnerabilities to a national CERT. In addition, we anonymized the manufacturer names and device model names. We will provide the non-anonymized information upon request.

12. Related work

Device discovery of IoT devices. Many studies conducted Internet-wide scans of (vulnerable) IoT devices (e.g., [6], [1], [2], [3], [15], [16]). We add to this work by being able to identify and contact the device owners, rather than the network operators where the devices reside. Kumar et al. [17] leveraged internal network scans of 83M consumer IoT devices in 16M homes and found that 7.1% of IoT devices and 14.6% of home routers supported at least either Telnet or FTP. In addition, 2.1% of Telnet devices and 17.4% of FTP devices had weak credentials. Our work contributes to this area by clarifying the causes of vulnerable devices in enterprise networks.

Security behaviors of device owners and manufacturers. Various studies found mixed security performance of manufacturers. Rodriguez et al. reported that 43% of manufacturers provide password-changing procedures, and 26% of manufacturers give some security advice [18]. Gutfleisch et al. conducted interviews with experts responsible for the security of medical IoT devices and identified that it is difficult to obtain security information from device manufacturers [19]. Regarding security patch releases of IoT devices, Nakajima et al. found that device vendors timely release the patches [20]. Our work documents manufacturer practices regarding default-risky configurations and poor information disclosure for non-consumer devices.

There is a wealth of work on IoT security practices of consumers, e.g., [7], [8]. While this is not directly relevant to our study, this work does highlight the importance of default settings and information disclosure. Zlatolas et al. found that 26.4% of the users have never changed security settings [21]. When analyzing organic user reviews of smart home devices, about one in ten mention security or privacy

concerns [22]. To better inform consumers, security labels on IoT devices have been proposed [23].

To the best of our knowledge, there is very little research about the security practices of IoT owners in enterprise environments. Where it does exist, it is a survey of self-reported security behaviors, without scan data on actual devices. Schrama et al. [24] found that security awareness and adoption intention are negatively related. A survey on security misconfigurations by sysadmins [25] found that lack of experience and knowledge were cited as the most common causes, though it did not focus on IoT. Compared to the above studies, our study targets both manufacturer and user perspectives and performs a combined analysis to clarify the causes of enterprise IoT misconfigurations.

Security notifications. There is a large area of work on security notifications, though mostly on non-IoT vulnerabilities or infections [26], [27], [28]. Remediation rates vary, though vulnerability notifications generally receive low rates [29]. This stands in contrast to the high remediation rates found in our study, perhaps because the notifications came from within the enterprise. [30] found moderate remediation rates, though this likely reflects the strong incentive of the devices being quarantined until remediated. Cetin et al. [31] studied the impact of ISP notifications on malware-infected IoT devices. They also found a high remediation rate for quarantined devices. Bouwmeester et al. investigated security notifications to 17 consumers having infected IoT devices [7]. Only 4 out of 17 customers fully completed the remediation steps. When it comes to enterprise networks, Sasaki et al. [4] conducted a study on remote management devices used in infrastructures. The researchers notified operators of 317 insecure devices by email and telephone and found that measures were taken for 58% of the devices when they could reach the persons in charge of the device. As in our study, once you reach actual owners, remediation rates are high.

Compared to most existing notification studies on Internet-exposed devices, our contribution is on remediation rates in an enterprise environment and on understanding the causes behind the presence of vulnerable devices.

13. Conclusion

We investigated the causes behind 185 IoT devices with exposed services in an enterprise network. To find the cause behind this problem we combined the device discovery with a survey of owners, network measurements on remediation success, a study of manufacturer manuals, a survey among manufacturers and a penetration test of the devices. This comprehensive approach allowed us to disentangle the factors at play. We find that many of these factors point to the responsibility of manufacturers. Their actions make it inevitable that the door is left open to attackers.

Acknowledgement

A part of this research was conducted in joint research with 00One, Inc. A part of this research was conducted in

“MITIGATE” project among “Research and Development for Expansion of Radio Wave Resources(JPJ000254)”, supported by the Ministry of Internal Affairs and Communications (MIC), Japan. A part of this research was conducted in the commissioned research (No.JPJ012368C05201) by National Institute of Information and Communications Technology (NICT), Japan. This work was partially supported by JSPS KAKENHI Grant Numbers 19H04111 and 21KK0178. This work has been partially supported by the INTERSCT project, grant nr. NWA.1160.18.301, funded by Netherlands Organisation for Scientific Research (NWO).

References

- [1] A. Cui and S. J. Stolfo, “A quantitative analysis of the insecurity of embedded network devices: Results of a wide-area scan,” in *Proceedings of the 26th Annual Computer Security Applications Conference*, ser. ACSAC '10, 2010, p. 97–106.
- [2] M. Nawrocki, T. C. Schmidt, and M. Wählisch, “Uncovering vulnerable industrial control systems from the internet core,” in *NOMS 2020 - 2020 IEEE/IFIP Network Operations and Management Symposium*, 2020, pp. 1–9.
- [3] M. Dahlmann, J. Lohmöller, I. B. Fink, J. Pennekamp, K. Wehrle, and M. Henze, “Easing the conscience with opc ua: An internet-wide study on insecure deployments,” in *Proceedings of the ACM Internet Measurement Conference*, ser. IMC '20, 2020, p. 101–110.
- [4] T. Sasaki, A. Fujita, C. H. Gañán, M. van Eeten, K. Yoshioka, and T. Matsumoto, “Exposed infrastructures: Discovery, attacks and remediation of insecure ics remote management devices,” in *2022 IEEE Symposium on Security and Privacy (SP)*, 2022, pp. 2379–2396.
- [5] F. Li, Z. Durumeric, J. Cxyz, M. Karami, M. Bailey, D. McCoy, S. Savage, and V. Paxson, “You’ve got vulnerability: Exploring effective vulnerability notifications,” in *25th USENIX Security Symposium (USENIX Security 16)*, Austin, TX, Aug. 2016, pp. 1033–1050.
- [6] A. Mirian, Z. Ma, D. Adrian, M. Tischer, T. Chuenchujit, T. Yardley, R. Berthier, J. Mason, Z. Durumeric, J. A. Halderman, and M. Bailey, “An internet-wide view of ics devices,” in *2016 14th Annual Conference on Privacy, Security and Trust (PST)*, 2016, pp. 96–103.
- [7] B. Bouwmeester, E. Rodríguez, C. Gañán, M. van Eeten, and S. Parkin, “‘the thing doesn’t have a name’: Learning from emergent Real-World interventions in smart home security,” in *Seventeenth Symposium on Usable Privacy and Security (SOUPS 2021)*, Aug. 2021, pp. 493–512.
- [8] E. Rodríguez, M. Fukink, S. Parkin, M. van Eeten, and C. Gañán, “Difficult for thee, but not for me: Measuring the difficulty and user experience of remediating persistent iot malware,” *arXiv preprint arXiv:2203.01683*, 2022.
- [9] “Owasp internet of things project,” https://wiki.owasp.org/index.php/OWASP_Internet_of_Things_Project#tab=IoT_Top_10.
- [10] 00one inc., “Karma,” 2022. [Online]. Available: <https://www.00one.jp/karma/>
- [11] E. Rodríguez, A. Noroozian, M. van Eeten, and C. H. Gañán, “Superspreaders: Quantifying the role of iot manufacturers in device infections,” 2021.
- [12] J. M. Blythe, N. Sombatrung, and S. D. Johnson, “What security features and crime prevention advice is communicated in consumer IoT device manuals and support pages?” *Journal of Cybersecurity*, vol. 5, no. 1, 06 2019, tyz005. [Online]. Available: <https://doi.org/10.1093/cybsec/tyz005>
- [13] H.-F. Hsieh and S. E. Shannon, “Three approaches to qualitative content analysis,” *Qualitative Health Research*, vol. 15, no. 9, pp. 1277–1288, 2005, pMID: 16204405. [Online]. Available: <https://doi.org/10.1177/1049732305276687>
- [14] J. Reason, *Human Error*. Cambridge University Press, 1990.
- [15] T. Ueda, T. Sasaki, K. Yoshioka, and T. Matsumoto, “An internet-wide view of connected cars: Discovery of exposed automotive devices,” ser. ARES '22, 2022.
- [16] A. K. Marnerides, V. Giotsas, and T. Mursch, “Identifying infected energy systems in the wild,” ser. e-Energy '19. New York, NY, USA: Association for Computing Machinery, 2019, p. 263–267. [Online]. Available: <https://doi.org/10.1145/3307772.3328305>
- [17] D. Kumar, K. Shen, B. Case, D. Garg, G. Alperovich, D. Kuznetsov, R. Gupta, and Z. Durumeric, “All things considered: An analysis of IoT devices on home networks,” in *28th USENIX Security Symposium (USENIX Security 19)*, Aug. 2019, pp. 1169–1185.
- [18] E. Rodríguez, A. Noroozian, M. van Eeten, and C. H. Gañán, “Superspreaders: Quantifying the role of iot manufacturers in device infections,” 2021.
- [19] M. Gutfleisch, M. Schöps, J. Hielscher, M. Cheney, S. Sayin, N. Schuhmacher, A. Mohamad, and M. A. Sasse, “Caring about iot-security – an interview study in the healthcare sector,” in *Proceedings of the 2022 European Symposium on Usable Security*, ser. EuroUSEC '22, 2022, p. 202–215.
- [20] A. Nakajima, T. Watanabe, E. Shioji, M. Akiyama, and M. Woo, “A pilot study on consumer iot device vulnerability disclosure and patch release in japan and the united states,” in *Proceedings of the 2019 ACM Asia Conference on Computer and Communications Security*, ser. Asia CCS '19, 2019, p. 485–492.
- [21] L. Nemec Zlatolas, N. Feher, and M. Hölbl, “Security perception of iot devices in smart homes,” *Journal of Cybersecurity and Privacy*, vol. 2, no. 1, pp. 65–73, 2022. [Online]. Available: <https://www.mdpi.com/2624-800X/2/1/5>
- [22] Swaathi Vetrivel, Veerle van Harten, Carlos H. Gañán, Michel van Eeten, and Simon Parkin, “Examining consumer reviews to understand security and privacy issues in the market of smart home devices,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023.
- [23] P. Emami-Naeini, Y. Agarwal, L. F. Cranor, and H. Hibshi, “Ask the experts: What should be on an iot privacy and security label?” in *2020 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2020, pp. 447–464.
- [24] V. Schrama, C. H. Gañán, D. Aschenbrenner, M. de Reuver, K. Borgolte, T. Fiebig, and T. Fiebig, “Understanding the knowledge gap: How security awareness influences the adoption of industrial iot,” in *20th Annual Workshop on the Economics of Information Security (WEIS 2020)*, 2020.
- [25] C. Dietrich, K. Krombholz, K. Borgolte, and T. Fiebig, “Investigating system operators’ perspective on security misconfigurations,” ser. CCS '18. Association for Computing Machinery, 2018.
- [26] B. Stock, G. Pellegrino, C. Rossow, M. Johns, and M. Backes, “Hey, you have a problem: On the feasibility of large-scale web vulnerability notification,” in *25th USENIX Security Symposium (USENIX Security 16)*, Austin, TX, Aug. 2016, pp. 1015–1032.
- [27] B. Stock, G. Pellegrino, F. Li, M. Backes, and C. Rossow, “Didn’t you hear me?—towards more successful web vulnerability notifications,” ser. Proceedings of the 25th Annual Symposium on Network and Distributed System Security (NDSS '18), 2018.
- [28] O. Cetin, C. Ganan, M. Korczynski, and M. van Eeten, “Make notifications great again: learning how to notify in the age of large-scale vulnerability scanning,” in *Workshop on the Economy of Information Security*, 2017.
- [29] C. Utz, M. Michels, M. Degeling, N. Marnau, and B. Stock, “Comparing large-scale privacy and security notifications,” *Privacy Enhancing Technologies*, vol. 2023, no. 3, pp. 173–193, 2023.
- [30] O. Çetin, C. Gañán, L. Alena, S. Tajalizadehkhoob, and M. van Eeten, “Tell me you fixed it: Evaluating vulnerability notifications via quarantine networks,” in *2019 IEEE European Symposium on Security and Privacy (EuroS&P)*, 2019, pp. 326–339.

- [31] O. Cetin, C. Hernandez Ganan, L. Altena, T. Kasama, D. Inoue, K. Tamiya, Y. Tie, K. Yoshioka, and M. van Eeten, “Cleaning up the internet of evil things: Real-world evidence on isp and consumer efforts to remove mirai,” in *Network and Distributed System Security Symposium (NDSS) 2019*, 2019.

Appendix A. Discovered devices

TABLE 15. TYPE OF DISCOVERED DEVICES AND THE NUMBER OF DEVICES (AND UNIQUE MODELS)

Device Type	Telnet or FTP	Telnet	FTP
Smart card reader	53 (2)	53 (2)	53 (2)
Printer/Multi-function printer	38 (27)	21 (16)	36 (25)
Electric current monitor	13 (2)	13 (2)	11 (1)
Display controller	11 (1)	0 (0)	11 (1)
NAS	11 (10)	1 (1)	10 (10)
Announcement broadcast system	8 (1)	0 (0)	8 (1)
Data logger	6 (2)	0 (0)	6 (2)
Earthquake early warning system	6 (2)	6 (2)	0 (0)
L2 switch	5 (2)	5 (2)	0 (0)
Wireless LAN access point	4 (2)	4 (2)	0 (0)
UPS	4 (2)	4 (2)	1 (1)
Wireless LAN controller	3 (1)	0 (0)	3 (1)
Energy monitor	3 (1)	0 (0)	3 (1)
Router	3 (1)	3 (1)	0 (0)
Network adapter for printer	2 (2)	2 (2)	2 (2)
Web camera	2 (2)	1 (1)	2 (2)
Black and white printer	2 (1)	0 (0)	2 (1)
Paperless recorder	1 (1)	0 (0)	1 (1)
HPLC controller*	1 (1)	1 (1)	0 (0)
Web conferencing system	1 (1)	1 (1)	0 (0)
Power supply Control	1 (1)	1 (1)	0 (0)
Backup storage	1 (1)	0 (0)	1 (1)
Total (IoT devices identified model No.)	179 (66)	116 (36)	150 (52)

* High-Performance Liquid Chromatography (HPLC) controller

Appendix B. Dates of device release, last release of manuals, and firmware last release

TABLE 16. DATES OF DEVICE RELEASE, LAST RELEASE OF MANUALS, AND FIRMWARE LAST RELEASE

	Release Date		
	Device	Latest man.	Latest FW
Average year	2012	2013	2017
Median year	2011	2013	2019
In 2019 or after	2	9	20
From 2015 to 2018	10	13	9
From 2010 to 2014	23	20	4
In 2009 or before	17	12	4
Total(Number of dates obtained)	52	54	37

Appendix C. Survey of recently released devices

We bought successor models of the devices in our campus network and conducted a detailed evaluation of

these devices. To identify successor models, which are often not explicitly identified in the manufacturer’s product description, we have designated models with incrementally higher numbers in their model number as successors. Specifically, we acquired eight models, as shown in Table 17, and analyzed their default configurations for Telnet/FTP functionality. In addition, we examined the manuals of these devices to identify any references to Telnet/FTP and to determine whether the associated security risks were explicitly discussed.

One of the eight devices had the Telnet service enabled by default. The device’s manual included a description of the Telnet service, but no security precautions. Two devices had FTP enabled by default. Of the two devices with FTP, two device manuals included descriptions of the FTP service, but one manual did not include security precautions. The two data loggers and one router did not have Telnet or FTP server capabilities. According to the manuals and configuration pages of the data loggers, these devices were specifically designed to access data via the cloud.

TABLE 17. SURVEY OF RECENTLY RELEASED DEVICES

Device type	Release year	Telnet			FTP		
		Enabled by default	Description in manual	Precaution in manual	Enabled by default	Description in manual	Precaution in manual
MFP*	2022	No	Yes	No	No	Yes	Yes
Web cam.	2023	No func.	-	-	Yes	Yes	No
Data logger	2022	No func.	-	-	No func.	-	-
Data logger	2022	No func.	-	-	No func.	-	-
Router	2022	No func.	-	-	No func.	-	-
Printer	2020	Yes	No	No	Yes	No	No
Printer	2020	No	No	No	No	No	No
Printer	2020	No	No	No	No	Yes	No

* Multi-function printer

Appendix D. Penetration tests

TABLE 18. IDENTIFIED VULNERABILITIES

Manufacturer	Device type	Vulnerabilities
A	Printer	XSS, CSRF
A	Network adopter for printer	CSRF
B	Printer	XSS*
C	Multi-function printer	CSRF, Improper authentication
D	Web camera	XSS, CSRF
E	Router	Insecure session ID
F	Data logger	XSS, CSRF, Improper authn., Improper session management, Plaintext storage of passwords

*The vulnerability has been fixed, and a CVE number has been issued.

Appendix E.

Template of notification email (first notification)

Dear [Name of a device owner]

This is [Name of a researcher at IT service center], a network manager at Information Technology Service Center. Thank you for your cooperation in operating the campus network.

I am contacting you not as a member of the Information Technology Service Center but as a faculty member who would like to ask for your cooperation.

In July and September 2021, as part of a research study led by [our laboratory information], we conducted a survey of the security status of devices connected to the campus network. (I participated in this survey as a research collaborator.)

Specifically, the survey includes network scans of devices connected to the campus network and an investigation of the following items.

- 1) Which ports are open on the devices?
- 2) How many devices are using unsupported or out-of-date firmware versions?
- 3) How many devices are still using the factory default IDs and passwords for accessing the management interface of IoT devices such as routers and printers?

The implementation of this research was discussed and approved by the CIO meeting (an official meeting of the university) held on May 17, 2021. The meeting includes the following members.

- CIO
- CISO
- Director of IT service center

<What we would like to ask>

In the scan, we identified the following devices whose responsible owner is [Name of the device owner].

- [IP address of the device]
- [IP address of the device]
- ...

[Description of security risk]

In regard to this matter, we would like to conduct a survey. We are very sorry to burden your busy schedule, but we would appreciate your cooperation with our research survey.

Details of the investigation request:

The attached Excel file has two sheets (for FTP and for Telnet). We apologize for the inconvenience, but please fill in this sheet as much as you know and send it to us. (If you have more than two devices to be surveyed, please write the information of all devices in the sheet)

If you are not comfortable sending back an email, we can visit your location and conduct an in-person interview and on-site survey. Please let us know if you would like us to visit your location for a face-to-face interview and on-site survey.

Please note that this survey will be used only for research survey purposes. Your responses will be statistically processed so that individuals cannot be identified.

Once again, we would appreciate your cooperation.

Appendix F.

Template of notification e-mail (second notification)

Dear [Name of a device owner]

This is [Name of a researcher at IT service center], a network manager at Information Technology Service Center. Thank you for your cooperation in operating the campus network.

About half a year ago, on [Date of the first notification], I sent the email with a questionnaire as a part of a research study led by [our laboratory information]. I received questionnaire answers from you on [Date of the first questionnaire answer received.]

Thank you very much for your support and cooperation with the questionnaire. I am writing to ask for your cooperation in the follow-up investigation regarding this matter.

In the previous questionnaire, you answered: [Owner's answers to the first questionnaire]

For the purpose of a follow-up, we conducted additional scans.
[Text according to remediated/not remediated (see below)]

<What we would like your cooperation with>

We apologize for the inconvenience, but we would like you to complete the attached follow-up questionnaire (Excel file).

There are several sheets ("FTP", "TELNET", "ID and Password" "Firmware") in the attached Excel file. I am very sorry to trouble you, but please fill in as much as you can on the sheet and send it to me by e-mail.

If sending it back by e-mail is troublesome, we may ask you to have a face-to-face interview and conduct a field survey. Please let me know if you would like the face-to-face interview.

This questionnaire answer will be used only for research purposes. The responses will be statistically processed so that individuals cannot be identified.

Thank you again for your kind cooperation.

Remediated case:

The FTP and TELNET services were not detected at the following IP addresses. Thus, it seems that the countermeasures have been taken as planned.

<IP address> ***.***.***.***

We believe that accumulating specific details of individual measures is extremely beneficial for improving the security of the campus network. I would like to ask you about the measures you have taken.

Not remediated case:

On [IP address of the device] we confirmed that FTP and TELNET ports are still open. Even if measures have been completed, there could be false positives and in reality there might not be a problem. Thus, I would like to confirm the actual situation of the devices.

Appendix G.

Questionnaires template to manufactures

To whom this may concern:

This is [Name of professor of our laboratory], CISO and an Associate Professor at [Name of our university]. By the security audit of our campus network, we have detected that your product [xxxx], used in our campus network, runs Telnet/FTP service(s). These services are outdated and known to be targeted by cyber-attacks.

We have looked at the user manuals of the product but were not able to find any/sufficient descriptions about the service. Therefore, we could not determine whether the device is secured or not with the service running. We would like to confirm the followings:

- 1) What are these services used for? What operations are expected to be done using the services?
- 2) Do the services run by default without configuration by the users?
- 3) What is the login credential for these services?
- 4) Does the device have any security measures to mitigate the damage in case it is compromised via the services? (e.g., restricting available commands or user privilege)

We need to confirm the above items to keep the secure operation of our campus network. Please contact us at your earliest convenience.

[Name of professor of our laboratory],
[Affiliation]
[Contact email address]

Appendix H.

Additional questionnaire about known default credential, old firmware, end-of-life devices

TABLE 19. QUESTIONNAIRES FOR KNOWN DEFAULT CREDENTIAL, OLD FIRMWARE, END-OF-LIFE DEVICES

Questions	Answer choices
Q1. What type of device, manufacturer, and model number is using each IP address?	(Free form)
Q2. What is the usage situation (e.g., installation location) of the relevant device?	(Free form)
Q3. A question depending on the risk: Did you change the default credential? / Please let us know the firmware update status / Please let us know the situation of manufacturer's support	Yes / No / Unknown Firmware is latest / Not latest / Unknown Support is not finished yet / Support is ended / Unknown
Q4. Were you aware of the risk?	Know / Didn't know
Q5. Please tell us why you are using the device in that condition.	(Free form)
Q6. Please tell us about the measures you intend to take.	I have already taken measures. / I am willing to take measures. / I am not willing to take measures. / I am willing to take measures, but don't know how.
Q7. If you do not plan to take measures, please let us know the reason.	(Free form)

Appendix I.

Meta-Review

The following meta-review was prepared by the program committee for the 2024 IEEE Symposium on Security and Privacy (S&P) as part of the review process as detailed in the call for papers.

I.1. Summary

The manuscript investigates the root causes of exposing Telnet and FTP services in a university network. After a network scan, the paper reports 185 IoT devices and 32 non-IoT devices exposing Telnet or FTP services. The paper then conducts a series of studies to understand if the users are aware of the risky services, if they are willing to secure their devices, if the device manuals inform the users, what the justification of the manufacturers is, what risks are incurred by the users due to the exposed services. A key conclusion of the paper is that exposed services are mostly driven by manufacturers choices.

I.2. Scientific Contributions

- Provides a Valuable Step Forward in an Established Field
- Independent Confirmation of Important Results with Limited Prior Research

I.3. Reasons for Acceptance

- 1) The study is well conducted and the effort that went into thoroughly characterizing the situation is appreciated by the reviewers.
- 2) The study sheds some light on the causes of exposed Telnet and FTP services in a University network in Japan.
- 3) The paper acknowledges the limited generalizability of the results.

I.4. Noteworthy Concerns

- 1) This is a small case study and the findings are fairly expected.
- 2) For the qualitative coding, a discussion is missing of how much disagreement had to be resolved during the resolution phase.
- 3) It would have be nice if some of the surveys had a little more depth in some places to better characterize the “why”.